



ADAMA E-SERVICE

Security Audit Report

1.1. Summary of findings

Types of Vulnerabilities	Level of Risks			
	HIGH	MEDIUM	LOW	TOTAL
Broken Access Control	✓			8
Mass Assignment (Privilege Escalation)	✓			
Customer Account Takeover	✓			
Stored Cross-Site Scripting (XSS)	✓			
Login Brute Force	✓			
File Upload Vulnerability	✓			
Cross-Window Approval Weakness	✓			
Security Misconfiguration (Default Credentials)	✓			4
Insecure File Storage		✓		
Missing Password Policy		✓		
Sensitive Data Exposure		✓		
Missing Security Headers		✓		
TOTAL				12

1.2. Project Objective

The main objective of this vulnerability assessment and penetration testing is to identify potential security vulnerabilities and provide technical, managerial, physical and human related recommendations to remediate them.

1.3. Project scope

The scope of this audit is for testing **ADAMA E-SERVICE web application** accessible through:-

- <https://eservice.adamacity.gov.et/>

1. Broken Access Control

❖ Description

The application fails to implement proper authorization checks on sensitive routes. After authenticating as a normal customer, it was possible to directly navigate to admin-only routes such as `/user/list` and `/customer/list`. This bypass allowed unauthorized viewing, modification, and management of high-privilege user accounts. The issue arises from relying only on the user's session for authentication without verifying their role or permission for each endpoint.

❖ Risk Level: **HIGH**

❖ Impact

- Unauthorized access to admin functionalities and sensitive data
- Ability to modify or delete privileged user information
- Potential full compromise of administrative operations

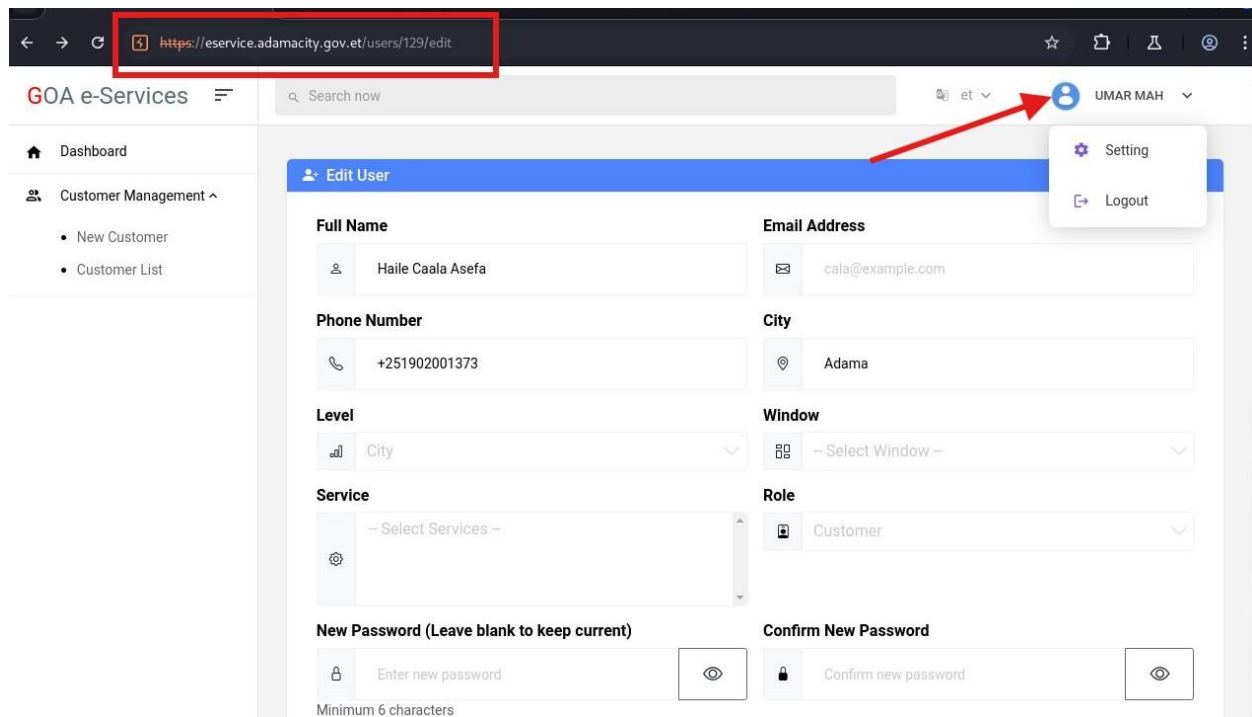
❖ Countermeasures

- **Implement strict server-side authorization:** Verify user roles and permissions on every request to admin endpoints.
- **Enforce RBAC frameworks:** Centralize and standardize role and attribute-based permissions at the API level.
- **Restrict sensitive endpoints:** Ensure admin routes are not exposed to non-admin roles by using middleware or access filters.

❖ Proof of concept

The screenshot shows the GOA e-Services application interface. The URL bar indicates the user is accessing `eservice.admacky.gov.et/user/list`. The user is logged in as 'INSATES'. The page displays a table of users, including 'Abebe Birhanu' with 'Super Admin' roles and 'Habtamu Abebe' with 'Officer' roles. The table is highlighted with a red box.

#	User	Contact	Window	Role	Services
1	Abebe Birhanu	0944837394	-	Super Admin	None
2	Abebe Birhanu	0944837393	-	Super Admin	None
3	Habtamu Abebe habtamu@gmail.com	0911745798	Window 5: Certification of Professional Competency	Officer	Issuance, renewal, and cancellation of professional licenses
4	dinknesh Kebede dinknesh@gmail.com	0913713947	Window 9: Business License	Officer	Issuance and renewal of Licenses and Certificates
5	Radiyaa Amaan radiyaa@gmail.com	0972871044	Window 12: Registration, Verification of Documents and Agreement	Officer	Filing and giving representations
6	Baaccuu Cimdeessaa baaccuu@gmail.com	0910730851	Window 12: Registration, Verification of Documents and Agreement	Officer	Executing government house agreements (kebele)



2. Mass Assignment (Privilege Escalation)

❖ Description

The customer registration endpoint allows arbitrary assignment of **role_id** from the client side. By manipulating the **role_id** parameter to a guessable super admin ID, attackers were able to register themselves as super admin users. This vulnerability stems from directly binding client-submitted fields to backend models without filtering sensitive attributes.

❖ Risk Level: **HIGH**

❖ Impact

- Creation of unauthorized super admin accounts
- Escalation of privileges to complete system control
- Loss of data integrity and trust

❖ Countermeasures

- **Block sensitive fields from client input:** Remove **role_id** and other privileged fields from the request payload and assign them server-side.
- **Use explicit DTOs (Data Transfer Objects):** Map only allowed parameters to the database layer.
- **Perform server-side validation:** Reject or sanitize any unexpected parameters.

❖ Proof of concept (POC)

← → <https://eservice.adamacity.gov.et/customer/registration> ☆ 📄 ⓘ 🔄 ⋮

e-Service | Adama Home ↗ Login

Customer Registration

Personal Information

Full Name

Abebe Birhanu

Gender

Male

Phone Number

0944837393

Security

Password

Confirm Password

Submit

🔍 Intercept on → Forward ▼ Drop 🔒 Request to https://eserv... 🔗 Open browser ?

Time	Type	Direction	Host	Method	URL	Status code	Lenat
09:04:55 22 S...	HTTP	→ Request	eservice.adamacity.gov.et	POST	https://eservice.adamacity.gov.et/custo...		

Request

Pretty Raw Hex 🔍 📄 ln ≡

```
1 POST /customer/registration HTTP/1.1
2 Host: eservice.adamacity.gov.et
3 Cookie: csrftoken=
4 eyJpdiI6ImJ3c0t0dGE7Mk11I0V8x2dpjH094Ww9Pp1sIn3hbHV12joendi18U9mdRkAHEp0TUCW6cck10uFMz0xkYzFCapVd1yV305L2tjb3BxV2hwM0dt2mdf0bWw0phbmFv3DB3bTFmCH12E6wE52vaKf93RtcU9G6U1RkFVYL21BUNF6c3H09c0cysp0mpFT2pa2V7N2DNUTH
5 C3TW6U10k0C0MPC1M0E30W0w7E0u1sYnCExtz0h3D8j30uy00v02Mj52jYz0y2D8hYj0w07118D1MjYyZTE0MTF11w4d0fNj01In0A3D: latave1_session=
6 eyJpdiI6ImJ3c0t0dGE7Mk11I0V8x2dpjH094Ww9Pp1sIn3hbHV12joendi18U9mdRkAHEp0TUCW6cck10uFMz0xkYzFCapVd1yV305L2tjb3BxV2hwM0dt2mdf0bWw0phbmFv3DB3bTFmCH12E6wE52vaKf93RtcU9G6U1RkFVYL21BUNF6c3H09c0cysp0mpFT2pa2V7N2DNUTH
7 C3TW6U10k0C0MPC1M0E30W0w7E0u1sYnCExtz0h3D8j30uy00v02Mj52jYz0y2D8hYj0w07118D1MjYyZTE0MTF11w4d0fNj01In0A3D: latave1_session=
8 eyJpdiI6ImJ3c0t0dGE7Mk11I0V8x2dpjH094Ww9Pp1sIn3hbHV12joendi18U9mdRkAHEp0TUCW6cck10uFMz0xkYzFCapVd1yV305L2tjb3BxV2hwM0dt2mdf0bWw0phbmFv3DB3bTFmCH12E6wE52vaKf93RtcU9G6U1RkFVYL21BUNF6c3H09c0cysp0mpFT2pa2V7N2DNUTH
9 C3TW6U10k0C0MPC1M0E30W0w7E0u1sYnCExtz0h3D8j30uy00v02Mj52jYz0y2D8hYj0w07118D1MjYyZTE0MTF11w4d0fNj01In0A3D: latave1_session=
10 Content-Length: 145
11 Cache-Control: max-age=0
12 Sec-Ch-Ua: "Chromium";v="125", "Not=A?Brand";v="6"
13 Sec-Ch-Ua-Mobile: ?0
14 Sec-Ch-Ua-Platform: "Windows"
15 Accept-Language: en-US,en;q=0.9
16 Origin: https://eservice.adamacity.gov.et
17 Content-Type: application/x-www-form-urlencoded
18 Upgrade-Insecure-Requests: 1
19 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/125.0.6668.71 Safari/537.36
20 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;vmb3;q=0.7
21 Sec-Fetch-Site: same-origin
22 Sec-Fetch-Mode: navigate
23 Sec-Fetch-User: ?1
24 Sec-Fetch-Dest: document
25 Referer: https://eservice.adamacity.gov.et/customer/registration
26 Accept-Encoding: gzip, deflate, br
27 Priority: u=0,i
28 Connection: keep-alive
29 _token=0U8gLE3jPh0tr0A1Dq7P81CkY1CZq0MF9756cni&name=Abebe+Birhanu&gender=mal&phone=0944837393&role=1&id=0&password=123456&confirm_password=123456
```

? ⚙️ ⬅️ ➡️ Search 🔍 0 highlights

#	User	Contact	Window	Role	Services
1	Abebe Birhanu	0944837393	-	Super Admin	None
2	test	+251965204504	-	Super Admin	None
3	Habtamu Abebe habtamua@gmail.com	0911745798	Window 5: Certification of Professional Competency	Officer	Issuance, renewal, and cancellation of professional qualification licenses for o
4	dinknesh Kebede dinknesh@gmail.com	0913713947	Window 9: Business License	Officer	Issuance and renewal of Licenses and Certificates of Recognition of Social As
5	Radiyas Amaan radiya@gmail.com	0972871044	Window 12: Registration, Verification of Documents and Agreement	Officer	Filing and giving representations
6	Baaccuu Cindeessaa baaccuu@gmail.com	0910730851	Window 12: Registration, Verification of Documents and Agreement	Officer	Executing government house agreements (kabele or condominium)
7	Aman Adaam amanadaam@gmail.com	0960991063	Window 10: Issuance of Various Letters of Support	Officer	Providing various letters of support
8	Damena Getachew damenagetachew@gmail.com	0911624840	Window 2: Provision of Investment Services	Officer	Issuance of investment licenses (New, Renewal, Replacement)
9	Makuria Dinku makuria.dinku@adamacity.gov.et	0911852342	Window 10: Issuance of Various Letters of Support	GOA Admin	Issue various letters of support to associations and Establish market linkages o

3. Customer Account Takeover

❖ Description

The password reset feature is insecure and accepts only a phone number to initiate a reset. Attackers can supply any customer's phone number to gain access to the password change endpoint without further verification, resulting in unauthorized account takeover.

❖ Risk Level: **HIGH**

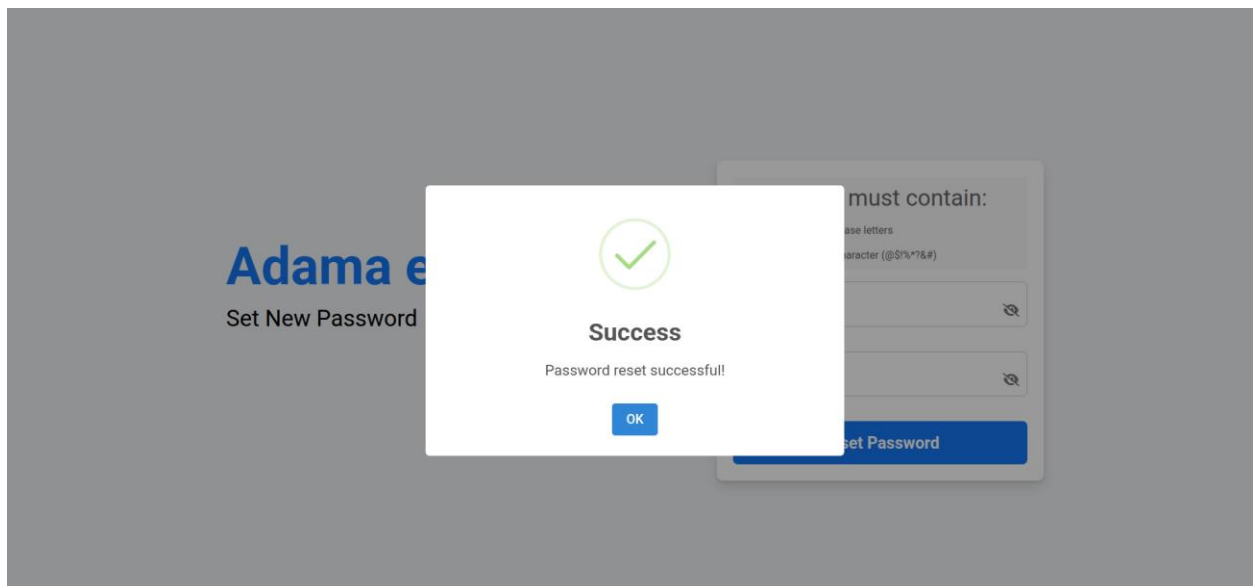
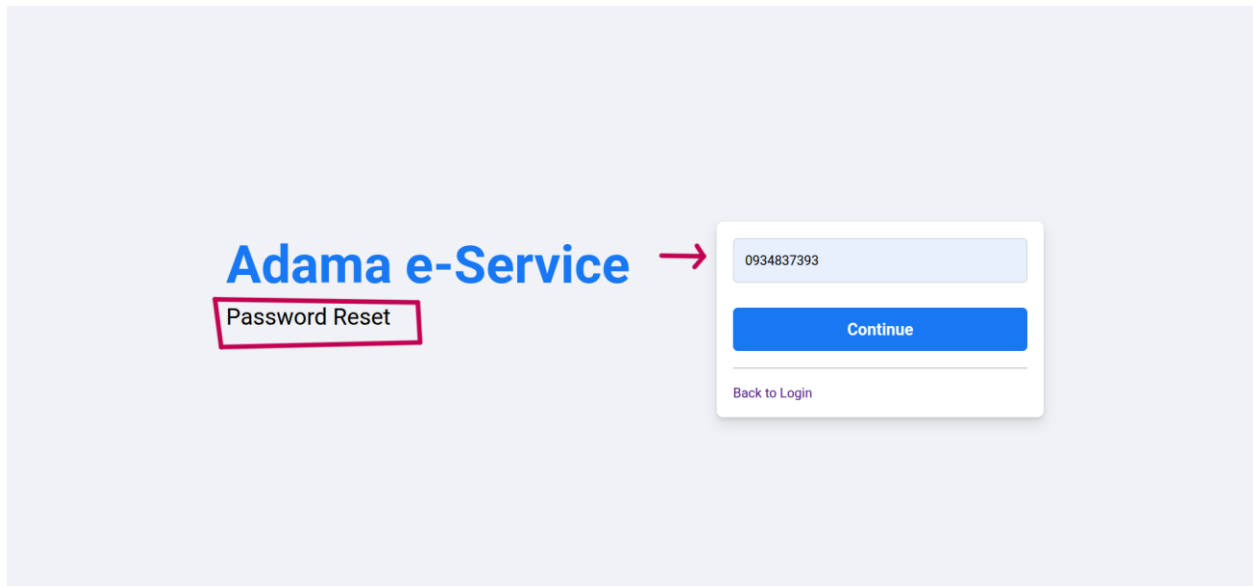
❖ Impact

- Unauthorized control over customer accounts
- Disclosure of personal data, transactions, and sensitive files
- Reputational and legal damage due to privacy breaches

❖ Countermeasures

- **Implement secure verification for password resets:** Use OTP codes, email tokens, or two-step verification before allowing password changes.
- **Confirm ownership of the account:** Require authentication of at least one verified factor (email, phone OTP).
- **Expire reset tokens promptly:** Ensure all reset links or codes are single-use and short-lived.

❖ **Proof of concept (POC)**



4. Stored Cross-Site Scripting (XSS)

❖ **Description**

The customer service application form allows malicious scripts to be stored without sanitization. When officers view these applications, the stored scripts execute in their browsers, potentially stealing credentials or performing actions on their behalf. This is a persistent vulnerability because malicious code is stored in the database and rendered back to privileged users.

❖ **Risk Level: HIGH**

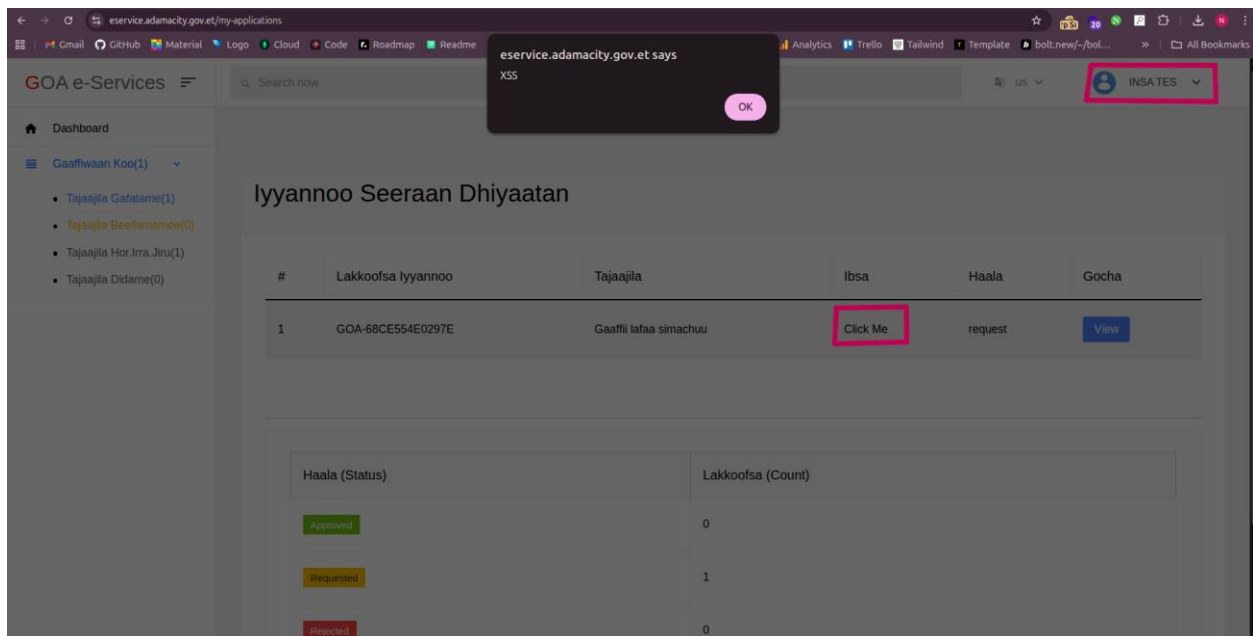
❖ Impact

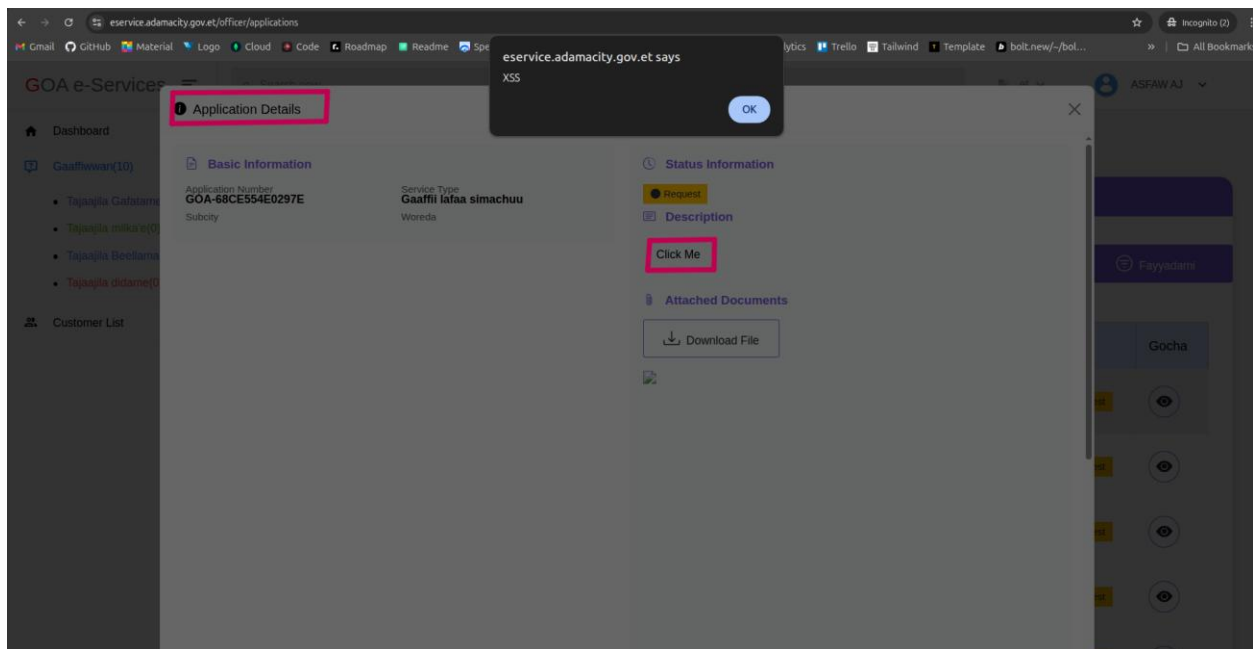
- Account hijacking of officers and admins
- Theft of session tokens and sensitive data
- Pivoting into internal systems for further compromise

❖ Countermeasures

- **Sanitize and encode all user inputs:** Use libraries to escape special characters before saving data.
- **Implement a Content Security Policy (CSP):** Restrict script execution sources to mitigate XSS impact.
- **Perform server-side and client-side validation:** Reject suspicious inputs at submission time.

❖ Proof of concept (POC)





5. Login Brute Force

❖ Description

The login endpoint does not restrict the number of failed login attempts. Attackers can automate password guessing attacks without encountering delays or lockouts, increasing the chance of account compromise through brute force or credential stuffing.

❖ Risk Level: **HIGH**

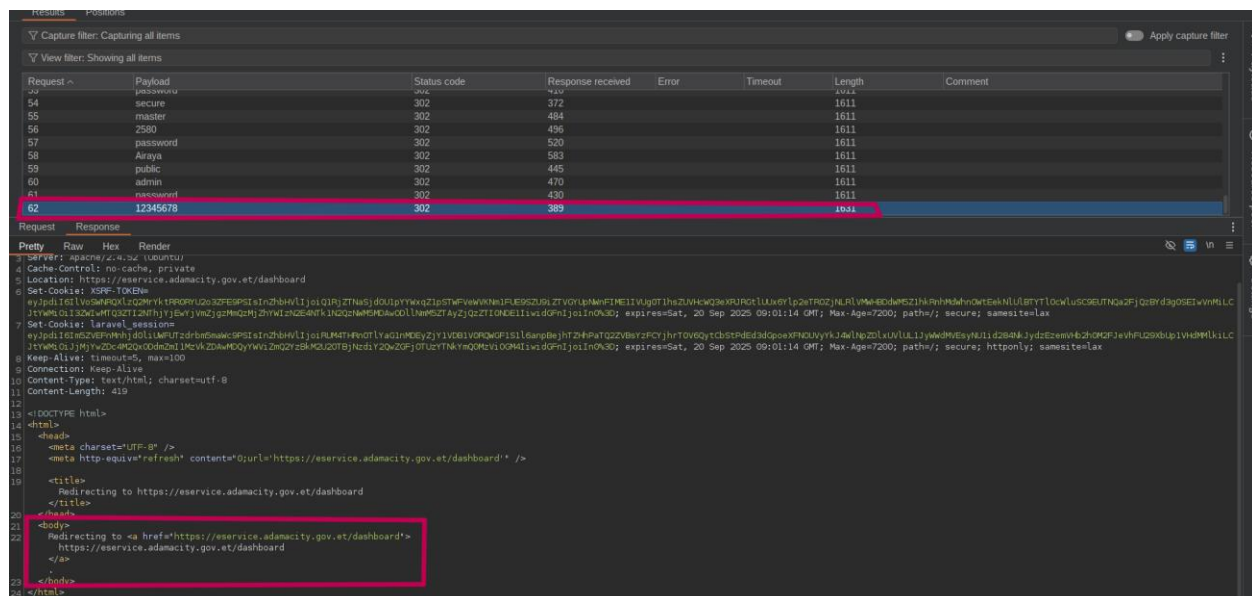
❖ Impact

- Unauthorized access to customer and admin accounts
- Increased risk of compromised credentials
- Potential mass account compromise

❖ Countermeasures

- **Implement rate limiting:** Throttle login attempts after a defined number of failures.
- **Add account lockout mechanisms:** Temporarily block access after repeated failed attempts.
- **Introduce CAPTCHA after threshold:** Add CAPTCHA or reCAPTCHA to mitigate automated attacks.

❖ Proof of concept (POC)



6. File Upload Vulnerability

❖ Description

The file upload endpoint does not validate the file types or contents of uploaded files, accepting any format including potentially malicious scripts. This allows attackers to upload dangerous files that may execute on the server or be used to launch phishing or malware attacks.

❖ Risk Level: HIGH

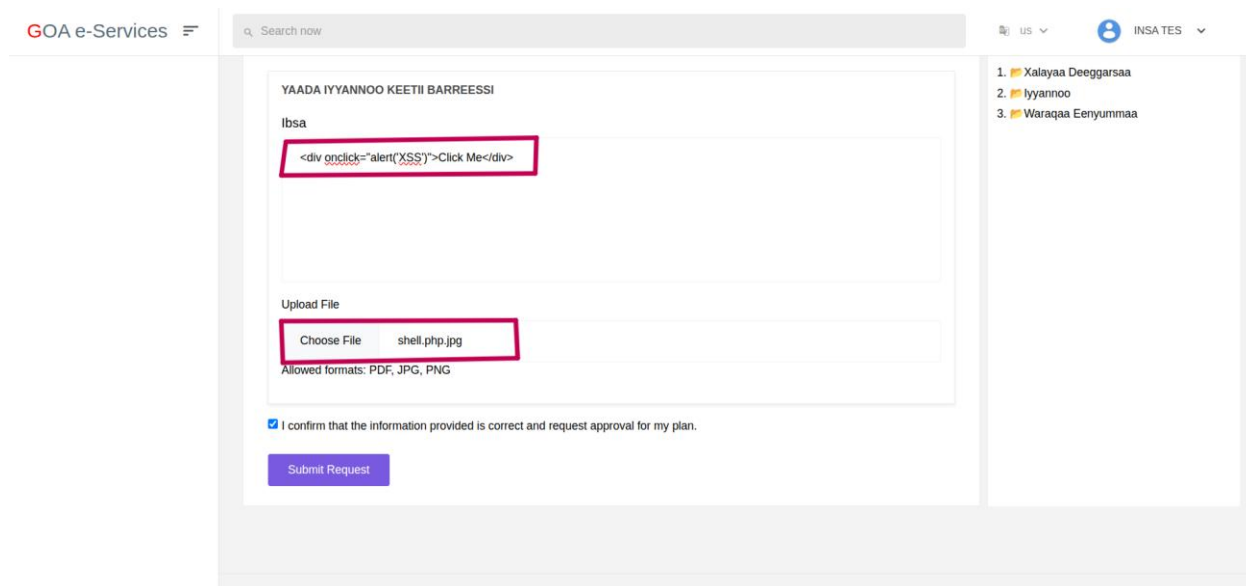
◆ Impact

- Remote code execution (RCE) if files are executed server-side
- Malware distribution or defacement of content
- Breach of sensitive system data

❖ Countermeasures

- **Restrict allowed file types and MIME types:** Allow only safe formats (e.g., PDF, JPEG) explicitly.
- **Scan uploaded files:** Use antivirus or sandboxing solutions before storing files.
- **Store files outside the web root:** Serve files via secure download handlers.

❖ Proof of concept (POC)



7. Cross-Window Approval Weakness

❖ Description

The system allows officers assigned to one service window (e.g., Provision of Land Service) to approve requests from another window (e.g., Provision of Investment Services) without proper authorization. This indicates a lack of context-based permissions and separation of duties.

❖ Risk Level: **HIGH**

❖ Impact

- Unauthorized approvals of services outside an officer's mandate
- Fraudulent or accidental approvals undermining integrity
- Regulatory compliance risks

❖ Countermeasures

- **Enforce strict context-based access controls:** Officers must only act on services tied to their assigned window.
- **Implement role segregation at the database level:** Filter accessible records per user context.
- **Introduce a double-approval mechanism for sensitive services:** Mitigate single-user abuse.

The screenshot displays the GOA e-Services portal interface. At the top, the browser address bar shows the URL 'eservice.adamacky.gov.et/office/applications'. The page header includes the 'GOA e-Services' logo and a search bar. The left sidebar contains navigation links for 'Dashboard' and 'Customer List'. The main content area features a purple header for 'Iyannoo Seeraan Dhiyaatan'. Below this, there are two tabs: 'Tajaajila Filadhu' and 'Guyyaa Xumuraa'. The 'Tajaajila Filadhu' tab is active, showing a dropdown menu with 'Filannoo' selected. To the right, there are two input fields for 'Guyyaa Jalqabaa' and 'Guyyaa Xumuraa', both containing the text 'dd/mm/yyyy'. A red box highlights the 'Qophii Lafaa Investimantii' cell in the table. The table has columns for '#', 'Maqaa Maamilaa', 'Lakkoofsa Iyannoo', 'Tajaajila', 'Ibsa', 'Haala', and 'Gocha'. The first row shows details for 'Mohammed Kufa' with the ID 'GOA-6895E7DD53A9E'. The 'Haala' column contains a 'Request' button, and the 'Gocha' column contains an eye icon.

#	Maqaa Maamilaa	Lakkoofsa Iyannoo	Tajaajila	Ibsa	Haala	Gocha
1	Mohammed Kufa	GOA-6895E7DD53A9E	Qophii Lafaa Investimantii	Iddoo waaqeffannaa lafaa akka nuuf kennamu Read More	Request	

The screenshot shows the developer tools of a web browser. The 'Request' tab on the left displays the raw HTTP request, and the 'Response' tab on the right displays the raw HTTP response. A red box highlights the 'Redirecting to https://eservice.adamacity.gov.et/officer/applications' message in the response body.

Request

```

1 GET /officer/applications/accept/5163 HTTP/1.1
2 Host: eservice.adamacity.gov.et
3 Cookie: XSFP: TOKEN=
  eyJpdjE1bnBhcnVwMpsZjBFRzFUT2RvOHRHKE9PSiSnZhbHVlIjo1SjUkZ3VFanpaaLUREVUw1IwZkOWdoY0p0
  MzBzZ201Vj0JzWlWkRkRmThThBhZkR6QjZoaFRodWl1SVVQMeqveExzbw05ajdoofLReUsmVUtdmDvPSStk2
  VmHPmZGdyZj00QWQWZDjFRhhiTEVjSVhrendVNGg3GjWaTElLCljTYWMIQ1JmVWVlM2NnN2RlYTc4YTQ2NjRm
  MkwkZGQyZjJmOGQyYTFYFjDOl1NzKzMc2mZTjxwNHRMc2U5NTQ2NTVhZnRmNmIiIiwidGF1Ijo1Iml0N3Q;
  laravel_session=
  eyJpdjE1bnBhcnVwMpsZjBFRzFUT2RvOHRHKE9PSiSnZhbHVlIjo1SjUkZ3VFanpaaLUREVUw1IwZkOWdoY0p0
  MzBzZ201Vj0JzWlWkRkRmThThBhZkR6QjZoaFRodWl1SVVQMeqveExzbw05ajdoofLReUsmVUtdmDvPSStk2
  VmHPmZGdyZj00QWQWZDjFRhhiTEVjSVhrendVNGg3GjWaTElLCljTYWMIQ1JmVWVlM2NnN2RlYTc4YTQ2NjRm
  MkwkZGQyZjJmOGQyYTFYFjDOl1NzKzMc2mZTjxwNHRMc2U5NTQ2NTVhZnRmNmIiIiwidGF1Ijo1Iml0N3Q;
  expires=Sun, 21 Sep 2025 14:17:39 GMT; Max-Age=7200; path=/; secure; samesite=lax
4 Sec-Ch-Ua: 'Not;A=Brand';v='99', 'Google Chrome';v='139', 'Chromium';v='139'
5 Sec-Ch-Ua-Mobile: 70
6 Sec-Ch-Ua-Platform: 'Linux'
7 Upgrade-Insecure-Requests: 1
8 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko)
  Chrome/139.0.0.0 Safari/537.36
9 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*
  /*;q=0.8,application/signed-exchange;v=b3;q=0.7
10 Sec-Fetch-Site: same-origin
11 Sec-Fetch-Mode: navigate
12 Sec-Fetch-User: ?1
13 Sec-Fetch-Dest: document
14 Referer: https://eservice.adamacity.gov.et/officer/applications
15 Accept-Encoding: gzip, deflate, br
16 Accept-Language: en-US,en;q=0.9,my;q=0.8,am;q=0.7
17 Priority: u=0, i
18 Connection: keep-alive
19
20

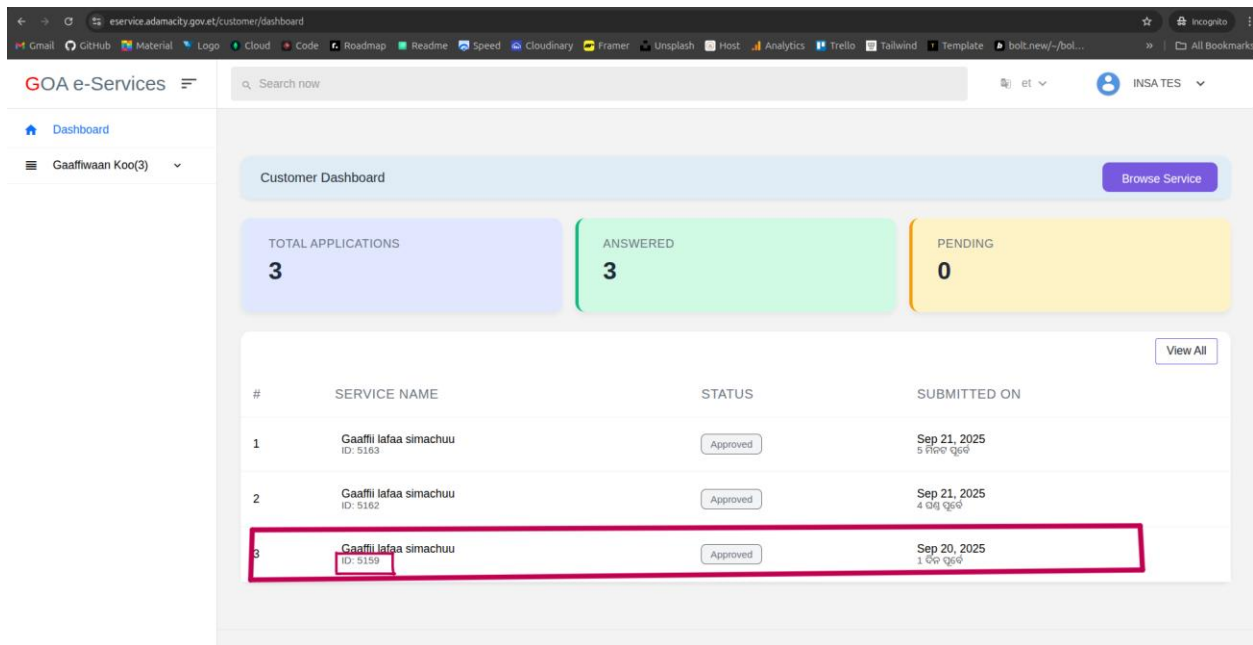
```

Response

```

1 HTTP/1.1 302 Found
2 Date: Sun, 21 Sep 2025 12:17:39 GMT
3 Server: Apache/2.4.52 (Ubuntu)
4 Cache-Control: no-cache, private
5 Location: https://eservice.adamacity.gov.et/officer/applications
6 Set-Cookie: XSFP: TOKEN=
  eyJpdjE1bnBhcnVwMpsZjBFRzFUT2RvOHRHKE9PSiSnZhbHVlIjo1SjUkZ3VFanpaaLUREVUw1IwZkOWdoY0p0
  MzBzZ201Vj0JzWlWkRkRmThThBhZkR6QjZoaFRodWl1SVVQMeqveExzbw05ajdoofLReUsmVUtdmDvPSStk2
  VmHPmZGdyZj00QWQWZDjFRhhiTEVjSVhrendVNGg3GjWaTElLCljTYWMIQ1JmVWVlM2NnN2RlYTc4YTQ2NjRm
  MkwkZGQyZjJmOGQyYTFYFjDOl1NzKzMc2mZTjxwNHRMc2U5NTQ2NTVhZnRmNmIiIiwidGF1Ijo1Iml0N3Q;
  expires=Sun, 21 Sep 2025 14:17:39 GMT; Max-Age=7200; path=/; secure; samesite=lax
7 Set-Cookie: laravel_session=
  eyJpdjE1bnBhcnVwMpsZjBFRzFUT2RvOHRHKE9PSiSnZhbHVlIjo1SjUkZ3VFanpaaLUREVUw1IwZkOWdoY0p0
  MzBzZ201Vj0JzWlWkRkRmThThBhZkR6QjZoaFRodWl1SVVQMeqveExzbw05ajdoofLReUsmVUtdmDvPSStk2
  VmHPmZGdyZj00QWQWZDjFRhhiTEVjSVhrendVNGg3GjWaTElLCljTYWMIQ1JmVWVlM2NnN2RlYTc4YTQ2NjRm
  MkwkZGQyZjJmOGQyYTFYFjDOl1NzKzMc2mZTjxwNHRMc2U5NTQ2NTVhZnRmNmIiIiwidGF1Ijo1Iml0N3Q;
  expires=Sun, 21 Sep 2025 14:17:39 GMT; Max-Age=7200; path=/; secure; samesite=lax;
8 Keep-Alive: timeout=5, max=100
9 Connection: Keep-Alive
10 Content-Type: text/html; charset=utf-8
11 Content-Length: 463
12
13 <!DOCTYPE html>
14 <html>
15   <head>
16     <meta charset='UTF-8' />
17     <meta http-equiv='refresh' content='
18       0;url=https://eservice.adamacity.gov.et/officer/applications/' />
19   <title>
20     Redirecting to https://eservice.adamacity.gov.et/officer/applications
21   </title>
22   <body>
23     Redirecting to <a href='https://eservice.adamacity.gov.et/officer/applications
24       https://eservice.adamacity.gov.et/officer/applications
25     </a>
26   </body>
27 </html>

```



8. Security Misconfiguration (Default Credentials)

❖ Description

New high-privilege users created in the admin panel are assigned default credentials which is **123456A@** password. Attackers can exploit unchanged defaults to gain unauthorized access to privileged accounts.

❖ Risk Level: **HIGH**

❖ Impact

- Compromise of admin accounts using default credentials
- Full control of system operations by unauthorized actors

❖ Countermeasures

- **Enforce password changes at first login:** Require all new users to set a unique password immediately.
- **Disable default credentials:** Randomize credentials for each new account.
- **Audit all user credentials:** Identify accounts still using defaults and force reset.

❖ Proof of concept (POC)

← → ↻ <https://eservice.adamacity.gov.et/login> 🌐 ☆ 📄 👤 ⌵

0913713947

.....

Login

[Forgot Your Password?](#)

 Sign in with Fayda

[Create account](#)

GOA e-Service

Adama City Administration

Tajaajila Elektirooniksii x +

← → ↻ <https://eservice.adamacity.gov.et/officer/dashboard> ☆ 📄 👤 ⌵

GOA e-Services

Search now

et ▼

 DINKNESH ▼

Dashboard

Gaaffiwwan(4)

Customer List

Baga Nagaan Dhufan! back,dinknesh Kebeda
Your analytics dashboard.

[Dashboard / Analytics](#)

2017 ▼ All Mo▼ Generate report

Overview Today Report

 kan Gafatamee
4

 kan Deebi'ee
4

 kan Didame
0

 Beelama
0

Tajaajiloota

Tajaajila Gafatamee

Tajaajila Deebi Argatee

Tajaajila Haqamee



Top 10 Most Requested Services

#	Service Name	Total Requests
1	Hayyamaa fi Ragaa Beekamtii Waldaalee Hawaasummaa kennuu fi haaromsuu	4

GOA e-Services

Search now

et

UMAR MAH

Level

City

Window

-- Select Window --

Service

-- Select Services --

Role

Customer

Back Office

-- Select office --

Department

-- Select department --

Profession

-- Select profession --

Password

123456A@

Confirm Password

123456A@

Signature

Browse... No file selected.

Upload a transparent PNG signature (max 2MB)

Official Stamp

Browse... No file selected.

9. Insecure File Storage

❖ Description

Confidential customer files are stored in a publicly accessible **/uploads/documents** directory without authentication or encryption. This exposes sensitive data to anyone with the URL or through automated crawlers.

❖ Risk Level: **MEDIUM**

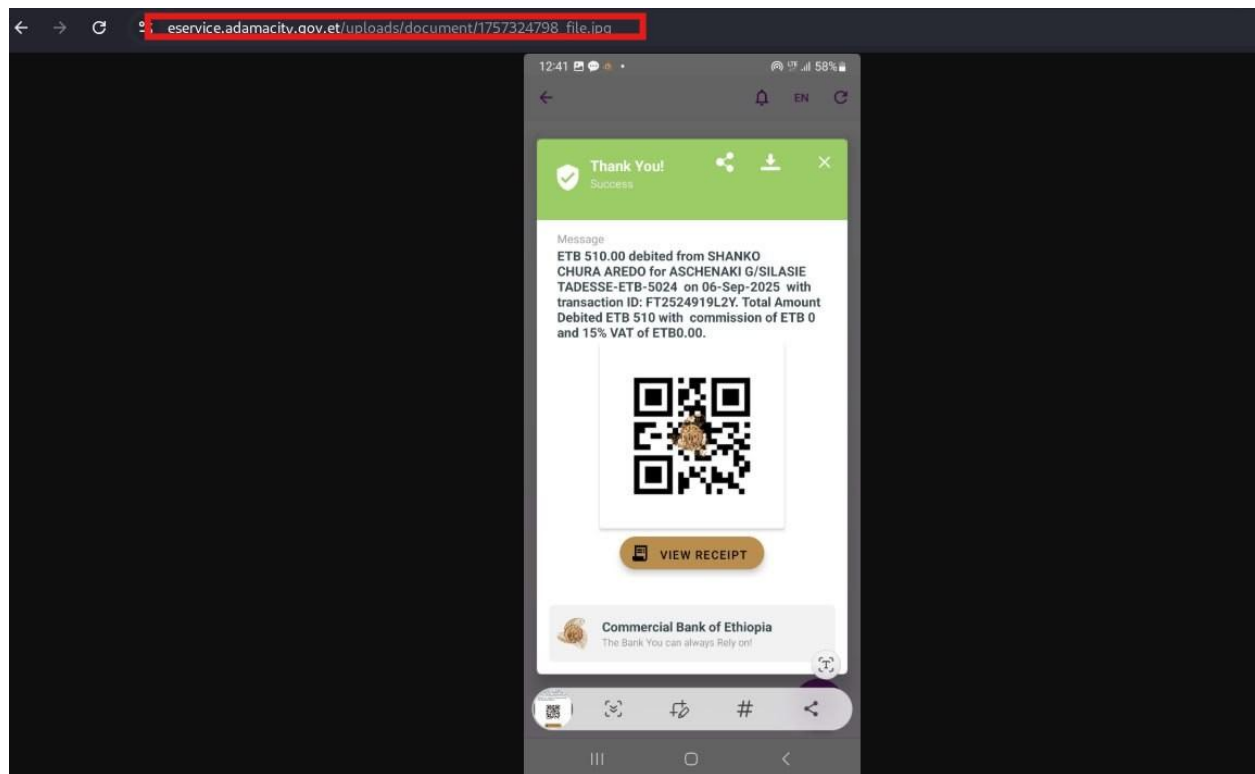
❖ Impact

- Unauthorized access to confidential files
- Privacy breaches and regulatory non-compliance (e.g., GDPR)
- Data harvesting by malicious actors

❖ Countermeasures

- **Move files to non-public storage:** Use private directories not directly served by the web server.
- **Serve files through authenticated endpoints:** Check permissions before granting downloads.
- **Encrypt sensitive files at rest:** Use strong encryption to protect data even if accessed.

❖ Proof of concept (POC)



10. Missing Password Policy

❖ Description

The application does not enforce any password complexity requirements. Users can register weak passwords, making them susceptible to brute-force and credential stuffing attacks.

❖ Risk Level: **MEDIUM**

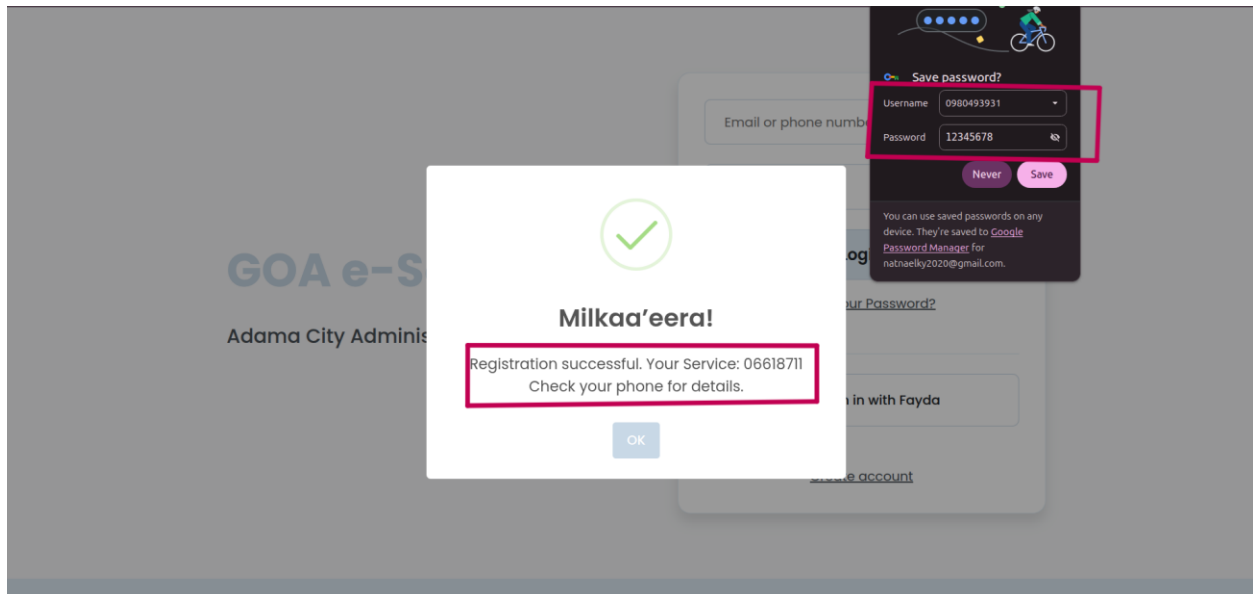
❖ Impact

- Increased likelihood of account compromise
- Reduced overall security posture

❖ Countermeasures

- **Define a strong password policy:** Minimum 8–12 characters, including uppercase, lowercase, numbers, and symbols.
- **Enforce policy server-side:** Reject passwords that don't meet requirements.
- **Integrate breached password checks:** Prevent known compromised passwords from being used.

❖ Proof of concept (POC)



11. Sensitive Data Exposure

❖ Description

Error messages reveal sensitive internal details such as framework versions and database structures. This information can help attackers map the system, identify software versions, and craft targeted exploits.

❖ Risk Level: MEDIUM

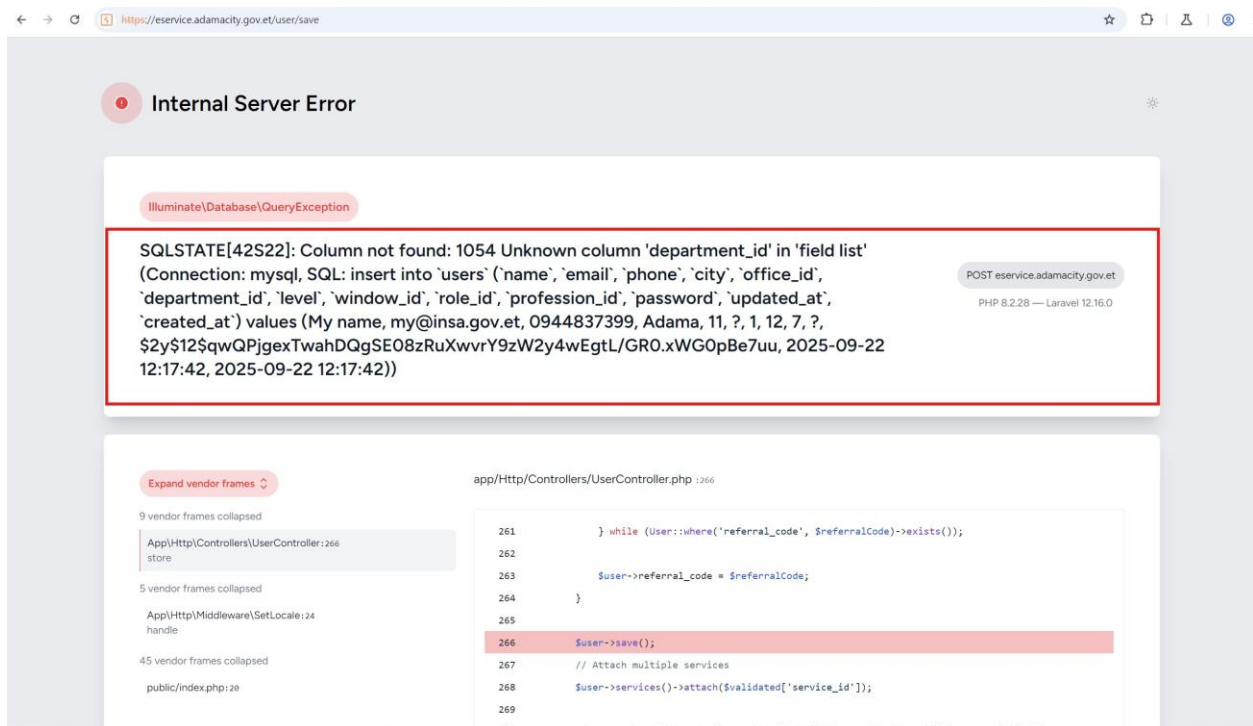
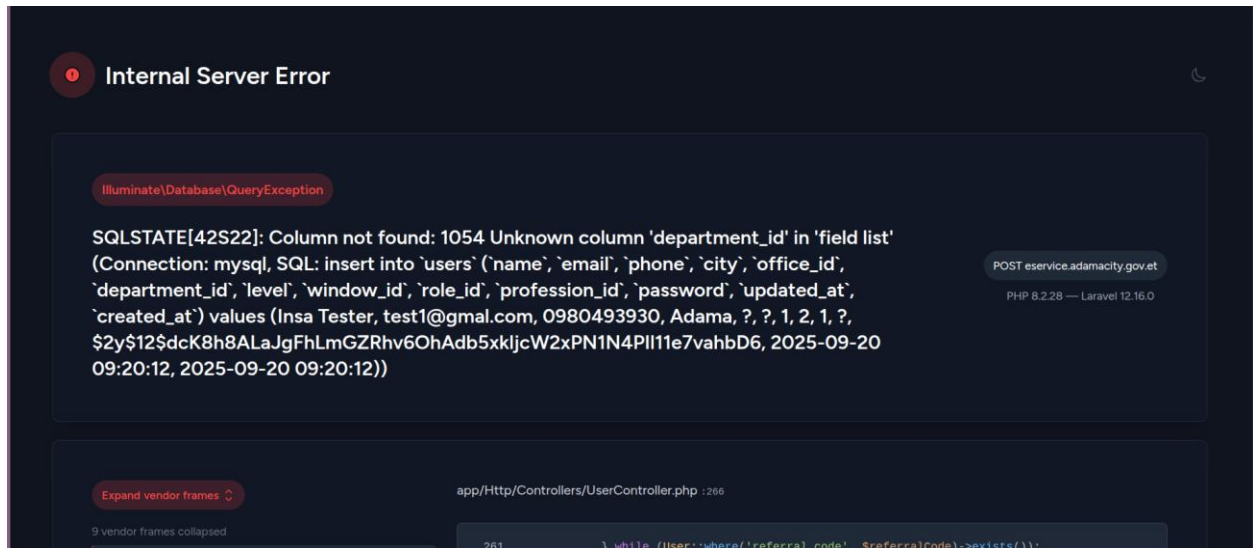
❖ Impact

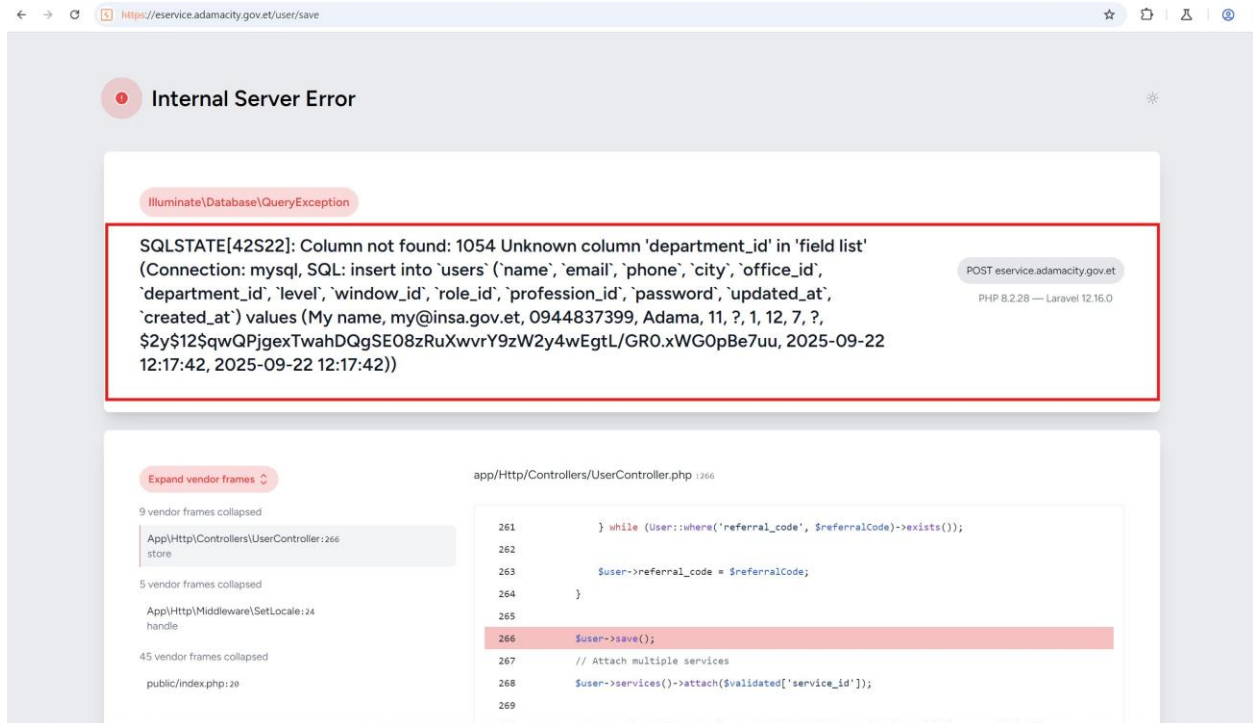
- Information leakage aiding attackers
- Easier exploitation of known vulnerabilities
- Increased success rate of attacks

❖ Countermeasures

- **Disable detailed error messages in production:** Show only generic error messages to end-users.
- **Log detailed errors securely:** Store stack traces and debug info in server logs, not in responses.
- **Sanitize exceptions:** Ensure error responses don't include sensitive data.

❖ Proof of concept (POC)





12. Missing Security Headers

❖ Description

The application does not include standard security-related HTTP headers (e.g., CSP, X-Frame-Options, X-Content-Type-Options, HSTS). Missing headers leave the application more vulnerable to common attacks like XSS, clickjacking, and MIME-type sniffing.

❖ Risk Level: **MEDIUM**

❖ Impact

- Increased exposure to client-side attacks
- Reduced protection from modern browser security features

❖ Countermeasures

- **Add modern security headers:** Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security (HSTS), Referrer-Policy, etc.
- **Apply environment-wide defaults:** Configure headers at the web server or framework level for consistency.

❖ **Proof of concept (POC)**

```
[*] Analyzing headers of https://eservice.adamacity.gov.et/
[*] Effective URL: https://eservice.adamacity.gov.et/
[!] Missing security header: X-Frame-Options
[!] Missing security header: X-Content-Type-Options
[!] Missing security header: Strict-Transport-Security
[!] Missing security header: Content-Security-Policy
[!] Missing security header: Referrer-Policy
[!] Missing security header: Permissions-Policy
[!] Missing security header: Cross-Origin-Embedder-Policy
[!] Missing security header: Cross-Origin-Resource-Policy
[!] Missing security header: Cross-Origin-Opener-Policy
-----
[!] Headers analyzed for https://eservice.adamacity.gov.et/
[+] There are 0 security headers
[-] There are not 9 security headers
```